Guide to the Secure Configuration of Red Hat Enterprise Linux 9

with profile DISA STIG for Red Hat Enterprise Linux 9

— This profile contains configuration checks that align to the
DISA STIG for Red Hat Enterprise Linux 9 V2R5.

In addition to being applicable to Red Hat Enterprise Linux 9, this
configuration baseline is applicable to the operating system tier of
Red Hat technologies that are based on Red Hat Enterprise Linux 9, such as:

- Red Hat Enterprise Linux Server
- Red Hat Enterprise Linux Workstation and Desktop
- Red Hat Enterprise Linux for HPC
- Red Hat Storage
- Red Hat Containers with a Red Hat Enterprise Linux 9 image

The SCAP Security Guide Project
https://www.open-scap.org/security-policies/scap-security-guide
This guide presents a catalog of security-relevant configuration settings for Red Hat Enterprise Linux 9. It is a rendering of content structured in the eXtensible Configuration Checklist Description Format (XCCDF) in order to support security automation. The SCAP content is is available in the `scap-security-guide` package which is developed at https://www.open-scap.org/security-policies/scap-security-guide.

Providing system administrators with such guidance informs them how to securely configure systems under their control in a variety of network roles. Policy makers and baseline creators can use this catalog of settings, with its associated references to higher-level security control catalogs, in order to assist them in security baseline creation. This guide is a *catalog, not a checklist*, and satisfaction of every item is not likely to be possible or sensible in many operational scenarios. However, the XCCDF format enables granular selection and adjustment of settings, and their association with OVAL and OCIL content provides an automated checking capability. Transformations of this document, and its associated automated checking content, are capable of providing baselines that meet a diverse set of policy objectives. Some example XCCDF *Profiles*, which are selections of items that form checklists and can be used as baselines, are available with this guide. They can be processed, in an automated fashion, with tools that support the Security Content Automation Protocol (SCAP). The DISA STIG, which provides required settings for US Department of Defense systems, is one example of a baseline created from this guidance.

Do not attempt to implement any of the settings in this guide without first testing them in a non-operational environment. The creators of this guidance assume no responsibility whatsoever for its use by other parties, and makes no guarantees, expressed or implied, about its quality, reliability, or any other characteristic.

Evaluation Characteristics

Evaluation target	ip-172-31-6-65.us-east-2.compute.internal
Benchmark URL	#scap_org.open-scap_comp_ssg-rhel9-xccdf.xml
Benchmark ID	xccdf_org.ssgproject.content_benchmark_RHEL-9

Benchmark version	0.1.79
Profile ID	xccdf_org.ssgproject.content_profile_stig
Started at	2026-03-03T00:25:52+00:00
Finished at	2026-03-03T00:25:52+00:00
Performed by	ec2-user
Test system	cpe:/a:redhat:openscap:1.3.13

CPE Platforms

- **cpe:/o:redhat:enterprise_linux:9**

Addresses

- **IPv4** 127.0.0.1
- **IPv4** 172.31.6.65
- **IPv6** 0:0:0:0:0:0:0:1
- **IPv6** fe80:0:0:0:6a:67ff:fe37:6789
- **MAC** 00:00:00:00:00:00
- **MAC** 02:6A:67:37:67:89

Compliance and Scoring

The target system did not satisfy the conditions of 20 rules! Furthermore, the results of 2 rules were inconclusive. Please review rule results and consider applying remediation.

Rule results

420 passed
20 failed
11 other

Severity of failed rules

0 other
5 low
10 medium
5 high

Score

Scoring system	Score	Maximum	Percent
urn:xccdf:scoring:default	95.874298	100.000000	95.87%

Rule Overview

Title	Severity	Result
Guide to the Secure Configuration of Red Hat Enterprise Linux 9 **20x fail** **2x error** **9x notchecked**		
System Settings **19x fail** **2x error** **6x notchecked**		
Installing and Maintaining Software **13x fail** **2x error** **2x notchecked**		
System and Software Integrity **7x fail** **2x error**		
Software Integrity Checking		
Federal Information Processing Standard (FIPS) **3x fail** **1x error**		
Enable Dracut FIPS Module	high	**fail**
Enable FIPS Mode	high	**error**
FIPS Must Use a Supported Subpolicy	medium	**fail**
Implement STIG Sub Crypto Policy	medium	**fixed**
Set kernel parameter 'crypto.fips_enabled' to 1	high	**fail**
System Cryptographic Policies **4x fail** **1x error**		
Install crypto-policies package	medium	**pass**
Configure BIND to use System Crypto Policy	high	**notapplicable**
Configure System Cryptography Policy	high	**error**
Configure Kerberos to use System Crypto Policy	high	**pass**
Configure Libreswan to use System Crypto Policy	high	**pass**
Configure SSH Client to Use FIPS 140 Validated Ciphers: openssh.config	high	**fail**
Configure SSH Server to Use FIPS 140-2 Validated Ciphers: opensshserver.config	medium	**fail**
Configure SSH Client to Use FIPS 140-2 Validated MACs: openssh.config	medium	**fail**
Configure SSH Server to Use FIPS 140-2 Validated MACs: opensshserver.config	medium	**fail**
Operating System Vendor Support and Certification		
Disk Partitioning **6x fail** **1x notchecked**		
Encrypt Partitions	high	**notchecked**

Title	Severity	Result
Ensure /home Located On Separate Partition	low	**fail**
Ensure /tmp Located On Separate Partition	low	**fail**
Ensure /var Located On Separate Partition	low	**fail**
Ensure /var/log Located On Separate Partition	low	**fail**
Ensure /var/log/audit Located On Separate Partition	low	**fail**
Ensure /var/tmp Located On Separate Partition	medium	**fail**
GNOME Desktop Environment		
Sudo		
System Tooling / Utilities		
Updating Software **1x notchecked**		
Ensure dnf Removes Previous Package Versions	low	**pass**
Ensure gpgcheck Enabled In Main dnf Configuration	high	**pass**
Ensure gpgcheck Enabled for Local Packages	high	**fixed**
Ensure gpgcheck Enabled for All dnf Package Repositories	high	**pass**
Ensure Red Hat GPG Key Installed	high	**pass**
Ensure Software Patches Installed	medium	**notchecked**
Account and Access Control **1x fail** **2x notchecked**		
Warning Banners for System Accesses		
Protect Accounts by Configuring PAM		
Protect Physical Console Access		
Protect Accounts by Restricting Password-Based Login **1x fail** **1x notchecked**		
Set Account Expiration Parameters **1x notchecked**		
Set Account Expiration Following Inactivity	medium	**fixed**
Assign Expiration Date to Temporary Accounts	medium	**notchecked**
Set Password Expiration Parameters		
Verify Proper Storage and Existence of Password Hashes		
Restrict Root Logins		

Title	Severity	Result
Ensure All Accounts on the System Have Unique User IDs	medium	**pass**
Only Authorized Local User Accounts Exist on Operating System	medium	**fail**
Ensure All Groups on the System Have Unique Group ID	medium	**pass**
Secure Session Configuration Files for Login Accounts **1x notchecked**		
Ensure that Users Have Sensible Umask Values		
Ensure Home Directories are Created for New Users	medium	**pass**
Ensure the Logon Failure Delay is Set Correctly in login.defs	medium	**fixed**
Limit the Number of Concurrent Login Sessions Allowed Per User	low	**fixed**
Set Interactive Session Timeout	medium	**fixed**
User Initialization Files Must Not Run World-Writable Programs	medium	**pass**
Ensure that Users Path Contains Only Local Directories	medium	**notchecked**
All Interactive Users Must Have A Home Directory Defined	medium	**pass**
All Interactive Users Home Directories Must Exist	medium	**pass**
All Interactive User Home Directories Must Be Group-Owned By The Primary Group	medium	**pass**
Ensure All User Initialization Files Have Mode 0740 Or Less Permissive	medium	**fixed**
All Interactive User Home Directories Must Have mode 0750 Or Less Permissive	medium	**pass**
Enable authselect	medium	**pass**
GRUB2 bootloader configuration **2x fail**		
Non-UEFI GRUB2 bootloader configuration **2x fail**		
Verify /boot/grub2/grub.cfg Group Ownership	medium	**pass**
Verify /boot/grub2/grub.cfg User Ownership	medium	**pass**
Set the Boot Loader Admin Username to a Non-Default Value	high	**fail**
Set Boot Loader Password in grub2	high	**fail**
The system must booted with init_on_free=1	medium	**fixed**
Enable Kernel Page-Table Isolation (KPTI)	low	**fixed**

Title	Severity	Result
Disable vsyscalls	medium	**fixed**
Configure Syslog		
Network Configuration and Firewalls **1x fail** **2x notchecked**		
firewalld **1x notchecked**		
Inspect and Activate Default firewalld Rules		
Strengthen the Default Ruleset **1x notchecked**		
Firewalld Must Employ a Deny-all, Allow-by-exception Policy for Allowing Connections to Other Systems	medium	**notchecked**
Configure Firewalld to Use the Nftables Backend	medium	**notapplicable**
IPSec Support **1x notchecked**		
Install libreswan Package	medium	**fixed**
Verify Any Configured IPSec Tunnel Connections	medium	**notchecked**
IPv6		
Kernel Parameters Which Affect Networking		
Uncommon Network Protocols		
Wireless Networking		
Network Manager		
Configure Multiple DNS Servers in /etc/resolv.conf	medium	**fail**
Ensure System is Not Acting as a Network Sniffer	medium	**pass**
File Permissions and Masks **1x fail**		
Verify Permissions on Important Files and Directories		
Restrict Dynamic Mounting and Unmounting of Filesystems		
Restrict Partition Mount Options		
Restrict Programs from Dangerous Execution Patterns **1x fail**		
Disable Core Dumps		
Enable ExecShield		
Memory Poisoning		

Title	Severity	Result
Disable storing core dumps	medium	**fixed**
Restrict Access to Kernel Message Buffer	low	**fixed**
Disable Kernel Image Loading	medium	**fixed**
Disallow kernel profiling by unprivileged users	low	**fixed**
Disable Access to Network bpf() Syscall From Unprivileged Processes	medium	**fixed**
Restrict usage of ptrace to descendant processes	medium	**fixed**
Harden the operation of the BPF just-in-time compiler	medium	**fixed**
Disable the use of user namespaces	medium	**fail**
SELinux **1x fail**		
Install policycoreutils-python-utils package	medium	**pass**
Install policycoreutils Package	low	**pass**
Ensure No Device Files are Unlabeled by SELinux	medium	**pass**
Elevate The SELinux Context When An Administrator Calls The Sudo Command	medium	**fail**
Configure SELinux Policy	medium	**pass**
Ensure SELinux State is Enforcing	high	**pass**
Services **1x fail** **2x notchecked**		
Base Services		
Cron and At Daemons		
Application Whitelisting Daemon		
FTP Server		
Mail Server Software		
NFS and RPC		
Network Time Protocol		
Obsolete Services		
SSH Server **1x notchecked**		
Configure OpenSSH Client if Necessary **1x notchecked**		

Title	Severity	Result
Verify the SSH Private Key Files Have a Passcode	medium	**notchecked**
Configure OpenSSH Server if Necessary		
Install OpenSSH client software	medium	**pass**
Install the OpenSSH Server Package	medium	**pass**
Enable the OpenSSH Service	medium	**pass**
Verify Group Who Owns SSH Server Configuration Files	medium	**pass**
Verify Owner on SSH Server Configuration Files	medium	**pass**
Verify Permissions on SSH Server Config File	medium	**pass**
Verify Group Who Owns SSH Server config file	medium	**pass**
Verify Group Who Owns SSH Server Configuration Files	medium	**pass**
Verify Owner on SSH Server config file	medium	**pass**
Verify Owner on SSH Server Configuration Files	medium	**pass**
Verify Permissions on SSH Server config file	medium	**pass**
Verify Permissions on SSH Server Config File	medium	**pass**
Verify Permissions on SSH Server Private *_key Key Files	medium	**pass**
Verify Permissions on SSH Server Public *.pub Key Files	medium	**pass**
The File /etc/ssh/sshd_config.d/50-redhat.conf Must Exist	medium	**pass**
System Security Services Daemon **1x fail** **1x notchecked**		
Certificate status checking in SSSD	medium	**fixed**
Enable Certmap in SSSD	medium	**fail**
Enable Smartcards in SSSD	medium	**fixed**
SSSD Has a Correct Trust Anchor	medium	**notchecked**
Configure SSSD to Expire Offline Credentials	medium	**pass**
USBGuard daemon		
X Window System		
System Accounting with auditd **1x notchecked**		
Configure auditd Rules for Comprehensive Auditing		

Title	Severity	Result
Configure auditd Data Retention **1x notchecked**		
Configure a Sufficiently Large Partition for Audit Logs	medium	**notchecked**
Configure auditd Disk Error Action on Disk Error	medium	**fixed**
Configure auditd Disk Full Action when Disk Space Is Full	medium	**fixed**
Configure auditd mail_acct Action on Low Disk Space	medium	**pass**
Configure auditd admin_space_left Action on Low Disk Space	medium	**fixed**
Configure auditd admin_space_left on Low Disk Space	medium	**fixed**
Configure auditd max_log_file_action Upon Reaching Maximum Log Size	medium	**pass**
Configure auditd space_left Action on Low Disk Space	medium	**fixed**
Configure auditd space_left on Low Disk Space	medium	**fixed**
Set number of records to cause an explicit flush to audit logs	medium	**fixed**
Include Local Events in Audit Logs	medium	**pass**
Resolve information before writing to audit logs	low	**pass**
Set type of computer node name logging in audit logs	medium	**fixed**
Appropriate Action Must be Setup When the Internal Audit Event Queue is Full	medium	**pass**
Write Audit Logs to the Disk	medium	**pass**
System Accounting with auditd		
Install audispd-plugins Package	medium	**fixed**
Ensure the audit Subsystem is Installed	medium	**pass**
Enable auditd Service	medium	**pass**
Enable Auditing for Processes Which Start Prior to the Audit Daemon	low	**fixed**
Extend Audit Backlog Limit for the Audit Daemon	low	**fixed**

Red Hat and Red Hat Enterprise Linux are either registered trademarks or trademarks of Red Hat, Inc. in the United States and other countries. All other names are registered trademarks or trademarks of their respective companies.